Vulnerability Assessment Report

Task 1 – Vulnerability Assessment

Target: OWASP Juice Shop
URL: http://127.0.0.1:3000
Environment: Local authorized laboratory
Assessment Type: Vulnerability assessment / passive analysis

1. Executive Summary

A vulnerability assessment was performed against an OWASP Juice Shop instance running in a local authorized laboratory environment. The assessment used Nmap for network/service discovery, OWASP ZAP for passive web security analysis, and manual HTTP header and response inspection. Several security observations were identified and manually reviewed where possible.

2. Scope

Target: OWASP Juice Shop
URL: http://127.0.0.1:3000
Environment: Local authorized laboratory
Assessment Type: Vulnerability assessment / passive analysis

3. Tools Used

Tool	Purpose
Nmap	Port and service discovery
OWASP ZAP	Passive web application security analysis
cURL	Manual HTTP response and header validation
Browser	Application inspection

4. Nmap Results

The host 127.0.0.1 was reachable and port 3000/tcp was open. Nmap did not identify the service name with confidence and reported "ppp?". This is treated as an unrecognized-service classification, not as confirmed PPP. The HTTP response fingerprint contained OWASP Juice Shop application content.

5. Findings Summary

ID	Finding	Risk	Validation
F01	Content Security Policy Header Not Set	Medium	Manually validated
F02	Cross-Domain Misconfiguration	Medium	Manually validated
F03	Missing Anti-clickjacking Header	Medium	Endpoint-specific
F04	Session ID in URL Rewrite	Medium	Partially validated
F05	Private IP Disclosure	Low	Observed; environment-specific
F06	Timestamp Disclosure – Unix	Low	Observed; low confidence
F07	X-Content-Type-Options Header Missing	Low	Endpoint-specific
F08	Information Disclosure – Suspicious Comments	Info	Observed; low confidence

6. Detailed Findings

F01 – Content Security Policy Header Not Set

Risk: Medium
Confidence: High
Target: http://127.0.0.1:3000/

Observation: The root HTTP response does not contain a Content-Security-Policy header.

Impact: The absence of CSP reduces a browser-side security control that can help restrict the sources from which web content may be loaded.

Evidence: Manual HTTP header inspection and ZAP alert F01.

Recommendation: Implement an appropriate Content Security Policy based on the application's required scripts, styles, images, connections, and other resources. Test the policy before enforcing it in production.

Limitation: The missing header alone does not prove that an XSS vulnerability exists.

F02 – Cross-Domain Misconfiguration

Risk: Medium
Confidence: Medium
Target: /polyfills.js

Observation: The response contains Access-Control-Allow-Origin: *.

Impact: A wildcard CORS policy permits cross-origin access to the resource. The security impact depends on what resources or data are exposed and whether credentials or sensitive information are involved.

Evidence: Manual HTTP response inspection and ZAP alert F02.

Recommendation: Restrict allowed origins to trusted origins where cross-origin access is required. Avoid wildcard CORS policies for sensitive resources.

Limitation: The wildcard header alone does not prove that sensitive data can be accessed cross-origin.

F03 – Missing Anti-clickjacking Header

Risk: Medium
Confidence: Medium
Target: Endpoint identified by ZAP

Observation: ZAP identified an application response without the expected anti-clickjacking protection. The root response contains X-Frame-Options: SAMEORIGIN.

Impact: Responses lacking appropriate framing restrictions may be more exposed to clickjacking attacks when they can be embedded by an untrusted origin.

Evidence: ZAP alert F03 and manual review of the root response.

Recommendation: Apply consistent anti-clickjacking protection to applicable application responses, using appropriate X-Frame-Options and/or CSP frame-ancestors controls.

Limitation: This finding is endpoint-specific and should not be described as a site-wide absence of X-Frame-Options.

F04 – Session ID in URL Rewrite

Risk: Medium
Confidence: High
Target: Socket.IO polling endpoint

Observation: The Socket.IO handshake response contains a sid value.

Impact: Session identifiers require appropriate protection to prevent unauthorized reuse.

Evidence: ZAP alert F04 and manual inspection of the Socket.IO response.

Recommendation: Use secure session-management mechanisms and avoid exposing sensitive session identifiers through URLs where applicable.

Limitation: The captured evidence shows the sid in the response body, not in the request URL. URL exposure has not been confirmed.

F05 – Private IP Disclosure

Risk: Low
Confidence: Medium
Target: /rest/admin/application-configuration

Observation: ZAP identified the private address 192.168.99.100:3000 in the response.

Impact: Internal network information can provide additional environmental information to an attacker.

Evidence: ZAP alert F05.

Recommendation: Avoid exposing internal infrastructure addresses in client-facing responses unless required.

Limitation: The assessment was performed against a local OWASP Juice Shop laboratory environment, so this observation is environment-specific.

F06 – Timestamp Disclosure – Unix

Risk: Low
Confidence: Low
Target: Endpoint identified by ZAP

Observation: ZAP identified the Unix timestamp 1666666667.

Impact: The available evidence does not establish a meaningful security impact.

Evidence: ZAP alert F06.

Recommendation: Review whether timestamps exposed to clients are necessary and avoid exposing sensitive internal timing information where unnecessary.

Limitation: This finding remains low-confidence and does not demonstrate a significant vulnerability by itself.

F07 – X-Content-Type-Options Header Missing

Risk: Low
Confidence: Medium
Target: Endpoint identified by ZAP

Observation: The root response contains X-Content-Type-Options: nosniff, while the inspected Socket.IO response does not contain the header.

Impact: Missing MIME-sniffing protection on applicable responses can reduce browser-side security hardening.

Evidence: ZAP alert F07 and manual HTTP header inspection.

Recommendation: Configure X-Content-Type-Options: nosniff consistently on applicable HTTP responses.

Limitation: This is an endpoint-specific observation and should not be described as a site-wide absence of the header.

F08 – Information Disclosure – Suspicious Comments

Risk: Informational
Confidence: Low
Target: /main.js

Observation: ZAP identified the term "query" as a potentially interesting source-code/comment reference.

Impact: No sensitive information disclosure was established from the available evidence.

Evidence: ZAP alert F08.

Recommendation: Review production JavaScript for unnecessary comments, debugging information, or sensitive implementation details before deployment.

Limitation: The available evidence does not demonstrate sensitive information disclosure.

7. Informational Scanner Observation

F09 – Modern Web Application
ZAP identified the application as a modern web application. This is an informational scanner observation and is not treated as a vulnerability.

8. Overall Recommendations

1. Implement and test an appropriate Content Security Policy.

2. Restrict CORS to trusted origins where required.

3. Apply anti-clickjacking protection consistently to applicable responses.

4. Review session-management and session-identifier exposure.

5. Remove unnecessary internal infrastructure information from client-facing responses.

6. Apply security headers consistently across applicable endpoints.

7. Review production JavaScript for unnecessary comments or debugging information.

9. Evidence

Supporting evidence is stored in the project repository under evidence/zap/, evidence/F01_manual_validation.txt through evidence/F08_manual_validation.txt, the HTTP response evidence files, evidence/nmap_summary.txt, and scans/nmap_scan.txt.

10. Assessment Limitation

This assessment was conducted against a locally hosted OWASP Juice Shop instance for authorized laboratory practice. The findings should not be represented as findings from a public production website or as evidence of vulnerabilities in an unrelated live system.